Secure University API Access Management

Software Requirements Specification

IEEE 830-1998 outline

DRAFT — human review required

Version 3 | 2026-10-30T04:13:08.476392+00:00

Contents

1 Introduction 4
1.1 Purpose . . . 4
1.2 Scope . . . 4
1.3 Definitions, acronyms and abbreviations . . . 4
1.4 References . . . 4
1.5 Overview . . . 4
2 Overall description 4
2.1 Product perspective . . . 4
2.2 Product functions . . . 5
2.3 User characteristics and stakeholders . . . 5
2.4 Constraints . . . 5
2.5 Assumptions and dependencies . . . 5
3 Specific requirements 6
3.1 External interface requirements . . . 6
3.1.1 User interfaces . . . 6
3.1.2 Hardware interfaces . . . 6
3.1.3 Software interfaces . . . 6
3.1.4 Communications interfaces . . . 6
3.2 Functional requirements . . . 6
3.3 Performance requirements . . . 7
3.4 Logical database requirements . . . 8
3.5 Design constraints . . . 8
3.6 Software system attributes . . . 8
3.6.1 Reliability . . . 8
3.6.2 Availability . . . 8
3.6.3 Security . . . 8
3.6.4 Maintainability . . . 8
3.6.5 Portability . . . 8
3.7 Other requirements . . . 8
A Derived threat hypotheses 9
A.1 THR-001: User identities and authenticated access . . . 9
A.2 THR-002: Role and permission boundaries . . . 9
A.3 THR-003: Access grants and revocations . . . 9
A.4 THR-004: Administrative security decisions . . . 10
A.5 THR-005: Integration trust paths . . . 10
A.6 THR-006: Security and administrative audit evidence . . . 10
A.7 THR-007: Monitoring and security alerts . . . 10
B Risk assessment 11
B.1 RISK-001 . . . 11
B.2 RISK-002 . . . 11
B.3 RISK-003 . . . 11
B.4 RISK-004 . . . 12
B.5 RISK-005 . . . 12
B.6 RISK-006 . . . 12
B.7 RISK-007 . . . 13
C SDLC recommendation and delivery workflow 13
C.1 Ranking and source evidence . . . 14
C.1.1 Incremental suitability reasons . . . 14
C.1.2 Hybrid suitability reasons . . . 14

C.1.3 DevSecOps suitability reasons . . . 15
C.1.4 Spiral suitability reasons . . . 15
C.1.5 Agile suitability reasons . . . 15
C.1.6 V-Model suitability reasons . . . 15
C.1.7 Waterfall suitability reasons . . . 15
C.2 Methodology phases . . . 15
C.2.1 Requirements and verification planning . . . 15
C.2.2 Incremental delivery cycle . . . 16
C.2.3 Release and handoff . . . 19

1 Introduction

1.1 Purpose

This specification records the project purpose, stakeholder constraints and unresolved decisions stated in the source evidence below.

This SRS describes the software's required behavior for users, administrators and the Project Analyst reviewing the specification.

1.2 Scope

Design a secure university API access management system that controls access to internal APIs used by student portals, administrative applications, research systems, and campus services. Authorized administrators should be able to register APIs, define access permissions, approve or revoke application access, and review active API clients. The system should authenticate API clients, enforce role- or policy-based access, detect repeated failed authentication and unauthorized API requests, generate security alerts, and maintain audit logs of access decisions, permission changes, and administrator actions. The platform should provide a centralized dashboard, integrate with existing university identity services, support multiple campus locations, and remain secure, reliable, scalable, and manageable.

1.3 Definitions, acronyms and abbreviations

Term	Meaning
Log	A collection of event records. This term does not itself require additional logging fields, events or access permissions.
Audit record	A stored record of an event. Required event scope and retention are determined by the linked source, not this definition.
Policy	A rule or decision governing permitted actions; its project-specific meaning remains defined by the source requirements.

1.4 References

Reference	Source
Format	IEEE Std 830-1998, clauses 5 and Annex A (document organization).

1.5 Overview

Section 2 summarizes the product, stakeholders and open decisions. Section 3 contains the uniquely identified requirements. Detailed evidence, acceptance procedures are available in the Normal report. Appendices A-C contain derived threat hypotheses, risk assessment and the proposed SDLC workflow.

2 Overall description

2.1 Product perspective

Design a secure university API access management system that controls access to internal APIs used by student portals, administrative applications, research systems, and campus services.

2.2 Product functions

Functional topics are summarized below; section 3 retains the full requirements.

- control access to internal APIs used by student portals, administrative applications, research systems, and campus services - FR-001
- allow Authorized administrators to register APIs - FR-002
- allow Authorized administrators to define access permissions - FR-003
- allow Authorized administrators to approve or revoke application access - FR-004
- allow Authorized administrators to review active API clients - FR-005
- authenticate API clients - FR-006
- enforce role- or policy-based access - FR-007
- detect repeated failed authentication - FR-008
- detect unauthorized API requests - FR-009
- generate security alerts - FR-010
- maintain audit logs of access decisions, permission changes, and administrator actions - FR-011
- provide a centralized dashboard - FR-012
- integrate with existing university identity services - FR-013
- support multiple campus locations - FR-014

2.3 User characteristics and stakeholders

Labels group stakeholders for readability. They do not combine permissions.

Education, training and experience requirements remain unspecified.

Role	Source user groups	Responsibility
User	student	Uses permitted functions; each source class keeps its specified permissions.
Admin	administrators	Performs only the role's source-defined operations in section 3.
Project Analyst	Document review role	Reviews requirements and tracks open decisions; this role grants no product access.

2.4 Constraints

No additional implementation constraints were confirmed. Source-defined restrictions remain in the requirements in section 3.

2.5 Assumptions and dependencies

Open decisions requiring confirmation:

- What conditions define repeated authentication failures?
- Which fields must the audit logs contain?
- What retention period is required for the audit logs?
- Which security acceptance outcomes must be demonstrated?

- What measurable reliability and recovery targets must the system meet?
- What measurable scalability targets must the system meet?
- What criteria define acceptable manageability?
- How are the stated roles and authorized permissions assigned?

3 Specific requirements

Each requirement is stated once with its original identifier and wording. Cross-references identify requirements covering more than one concern.

3.1 External interface requirements

3.1.1 User interfaces

Related requirements: FR-012. Interface details beyond those requirements remain unspecified.

3.1.2 Hardware interfaces

No specific interface requirement was supplied; confirmation is required.

3.1.3 Software interfaces

Related requirements: FR-008, FR-013. Interface details beyond those requirements remain unspecified.

3.1.4 Communications interfaces

No specific interface requirement was supplied; confirmation is required.

3.2 Functional requirements

FR-001 · Must · explicit

The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.

Traceability: E-001, TEST-001

FR-002 · Should · explicit

The system shall allow Authorized administrators to register APIs.

Traceability: E-002, TEST-002

FR-003 · Should · explicit

The system shall allow Authorized administrators to define access permissions.

Traceability: E-002, TEST-003

FR-004 · Should · explicit

The system shall allow Authorized administrators to approve or revoke application access.

Traceability: E-002, TEST-004

FR-005 · Should · explicit

The system shall allow Authorized administrators to review active API clients.

Traceability: E-002, TEST-005

FR-006 · Should · explicit

The system shall authenticate API clients.

Traceability: E-003, TEST-006

FR-007 · Should · explicit

The system shall enforce role- or policy-based access.

Traceability: E-003, TEST-007

FR-008 · Should · explicit

The system shall detect repeated failed authentication.

Traceability: E-003, TEST-008

FR-009 · Should · explicit

The system shall detect unauthorized API requests.

Traceability: E-003, TEST-009

FR-010 · Should · explicit

The system shall generate security alerts.

Traceability: E-003, TEST-010

FR-011 · Should · explicit

The system shall maintain audit logs of access decisions, permission changes, and administrator actions.

Traceability: E-003, TEST-011

FR-012 · Should · explicit

The system shall provide a centralized dashboard.

Traceability: E-004, TEST-012

FR-013 · Should · explicit

The system shall integrate with existing university identity services.

Traceability: E-004, TEST-013

FR-014 · Should · explicit

The system shall support multiple campus locations.

Traceability: E-004, TEST-014

3.3 Performance requirements

NFR-004 · Should · explicit

The system shall remain scalable.

Traceability: E-004, TEST-018

3.4 Logical database requirements

No separate requirement was specified in the supplied brief.

3.5 Design constraints

No separate requirement was specified in the supplied brief.

3.6 Software system attributes

3.6.1 Reliability

NFR-003 · Should · explicit

The system shall remain reliable.

Traceability: E-004, TEST-017

3.6.2 Availability

No separate requirement was specified in the supplied brief.

3.6.3 Security

Also covered by: FR-003, FR-006, FR-008, FR-010, FR-011.

NFR-001 · Must · explicit

The system shall be secure.

Traceability: E-001, TEST-015

NFR-002 · Should · explicit

The system shall remain secure.

Traceability: E-004, TEST-016

3.6.4 Maintainability

NFR-005 · Should · explicit

The system shall remain manageable.

Traceability: E-004, TEST-019

3.6.5 Portability

No separate requirement was specified in the supplied brief.

3.7 Other requirements

No separate requirement was specified in the supplied brief.

A Derived threat hypotheses

These are defensive planning hypotheses, not observed incidents or approved extra controls. Unrecognized threats and actual implementation effectiveness require human review.

These are planning hypotheses, not observed incidents or additional approved controls.

A.1 THR-001: User identities and authenticated access

Scenario: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Unauthorized use of a legitimate identity could expose resources or alter system state.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-003, E-004

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.2 THR-002: Role and permission boundaries

Scenario: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the source-defined authorization boundary.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: A lower-privilege user could access restricted functions or sensitive resources.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-002, E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.3 THR-003: Access grants and revocations

Scenario: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: A formerly authorized principal could continue using access that is no longer approved.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-002, E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.4 THR-004: Administrative security decisions

Scenario: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Misused administrative authority could undermine protection or interrupt legitimate use.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.5 THR-005: Integration trust paths

Scenario: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Untrusted integration data could cause incorrect decisions or hide security events.

Linked requirements: FR-012, FR-013, FR-014, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.6 THR-006: Security and administrative audit evidence

Scenario: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Investigators could lose reliable evidence of the events required by the brief.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

A.7 THR-007: Monitoring and security alerts

Scenario: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Hypothetical actor or cause: Hypothetical attacker, privileged insider or failure cause

Potential consequence: Relevant suspicious activity could remain undetected or receive delayed investigation.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

Residual exposure: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

B Risk assessment

Risk treatments are proposals for review. Unknown likelihood and impact ratings mean unassessed; no numeric confidence or severity is inferred.

B.1 RISK-001

Derived risk affecting User identities and authenticated access: Unauthorized use of a legitimate identity could expose resources or alter system state.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Proposed treatment: Review impersonation and compromised-identity paths against the stated access duties; confirm any additional identity or session protections with the stakeholder. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-003, E-004

B.2 RISK-002

Derived risk affecting Role and permission boundaries: A lower-privilege user could access restricted functions or sensitive resources.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the source-defined authorization boundary.

Proposed treatment: Test permitted and denied role/resource pairs against the linked authorization duties; review ambiguous permission assignments with the resource owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-002, E-003

B.3 RISK-003

Derived risk affecting Access grants and revocations: A formerly authorized principal could continue using access that is no longer approved.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Proposed treatment: Trace permission changes through subsequent access decisions and any active access; confirm revocation timing and session semantics before baselining them. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-002, E-003

B.4 RISK-004

Derived risk affecting Administrative security decisions: Misused administrative authority could undermine protection or interrupt legitimate use.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Proposed treatment: Review misuse cases for each source-permitted administrative operation and compare its outcomes and audit coverage with the stated management boundary. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

B.5 RISK-005

Derived risk affecting Integration trust paths: Untrusted integration data could cause incorrect decisions or hide security events.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Proposed treatment: Review trust assumptions at the specified integration boundaries with missing or altered input fixtures; confirm the required failure handling with the owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-012, FR-013, FR-014, NFR-002, NFR-003, NFR-004, NFR-005

Original evidence: E-004

B.6 RISK-006

Derived risk affecting Security and administrative audit evidence: Investigators could lose reliable evidence of the events required by the brief.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Proposed treatment: Compare source-required events with the resulting audit evidence; assess missing and altered-record cases and confirm unprovided protection or retention decisions. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

B.7 RISK-007

Derived risk affecting Monitoring and security alerts: Relevant suspicious activity could remain undetected or receive delayed investigation.

Likelihood: unknown; impact: unknown; owner: TBD.

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Proposed treatment: Evaluate the stated detection duties with representative positive and negative events; confirm undecided thresholds, alert priorities and investigation responsibilities. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Linked requirements: FR-006, FR-007, FR-008, FR-009, FR-010, FR-011

Original evidence: E-003

C SDLC recommendation and delivery workflow

Proposed lifecycle: Incremental

Security decisions benefit from security review and tests throughout delivery (E-002, E-003); monitoring and alert behavior needs validation with operational feedback (E-003); multiple deployment locations offer a staged validation and rollout opportunity (E-004); connected systems need integration verification before broader rollout (E-004). These derived factors support incremental delivery over continuous or sequential models, as staged assurance and repeated integration are more aligned with iterative output than fixed release cycles.

Recommendation requires human confirmation of delivery constraints and team capacity. Suitability points are deterministic rule scores, not probabilities.

Policy version: sequential-sdlc-2.0

Unconfirmed decision factors: budget, delivery, failure consequences, feedback, legacy, regulation, schedule, stability, uncertainty, verification

- Recurring delivery requires stakeholder review and backlog refinement; a cycle does not guarantee completeness or remove unresolved decisions.
- Proposed suitability recommendation; confirm delivery constraints and team capacity before adopting this lifecycle. Missing factors are not assumed.

C.1 Ranking and source evidence

- security_assurance = integrated security review (derived). Security decisions benefit from security review and tests throughout delivery. Original evidence: E-002, E-003.
- operational_validation = monitoring feedback (derived). Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. Original evidence: E-003.
- deployment_scope = staged rollout opportunity (derived). Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. Original evidence: E-004.
- integration_assurance = integration validation (derived). Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. Original evidence: E-004.

Candidate	Suitability points
Incremental	66
Hybrid	65
DevSecOps	63
Spiral	51
Agile	40
V-Model	40
Waterfall	40

C.1.1 Incremental suitability reasons

- Derived operational_validation (+6 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+12 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)
- Derived integration_assurance (+8 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.2 Hybrid suitability reasons

- Derived security_assurance (+8 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003)
- Derived operational_validation (+5 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+8 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)
- Derived integration_assurance (+4 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.3 DevSecOps suitability reasons

- Derived security_assurance (+12 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003)
- Derived operational_validation (+8 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003)
- Derived deployment_scope (+3 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)

C.1.4 Spiral suitability reasons

- Derived security_assurance (+5 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003)
- Derived integration_assurance (+6 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

C.1.5 Agile suitability reasons

- No differentiating input evidence

C.1.6 V-Model suitability reasons

- No differentiating input evidence

C.1.7 Waterfall suitability reasons

- No differentiating input evidence

C.2 Methodology phases

Activities reference the canonical requirements and proposed verification work. Human gates are pending decisions, not approval records.

C.2.1 Requirements and verification planning

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review and baseline the source-defined work group: FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.; FR-002: The system shall allow Authorized administrators to register APIs.; FR-003: The system shall allow Authorized administrators to define access permissions.; FR-004: The system shall allow Authorized administrators to approve or revoke application access.; FR-005: The system shall allow Authorized administrators to review active API clients.; FR-006: The system shall authenticate API clients.; FR-007: The system shall enforce role- or policy-based access.; FR-008: The system shall detect repeated failed authentication.; FR-009: The system shall detect unauthorized API requests.; FR-010: The system shall generate security alerts.; FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.; FR-012: The system shall provide a centralized dashboard.; FR-013: The system shall integrate with existing university identity services.; FR-014: The system shall support multiple campus locations.

- Activity: Review and baseline the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
- Activity: Create the unit, integration, system and acceptance test plan before implementation; retain each authored acceptance criterion.
- Deliverable: Versioned requirements baseline
- Deliverable: Unit, integration, system and acceptance test plan
- Deliverable: Unresolved-decision record
- Entry criterion: Authoritative inputs and canonical requirements are available for review.
- Exit criterion: A human reviewer has recorded the baseline decision and disposition of unresolved scope.
- Security check: Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
- Security check: Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
- Security check: Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.
- Security check: Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
- Security check: Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.
- Security check: Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.
- Security check: Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

C.2.2 Incremental delivery cycle

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review and prioritize the backlog for the next iteration without changing source-defined scope.
- Activity: Implement the source-defined work group: FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.; FR-002: The system shall allow Authorized administrators to register APIs.; FR-003: The system shall allow Authorized administrators to define access permissions.; FR-004: The system

shall allow Authorized administrators to approve or revoke application access.; FR-005: The system shall allow Authorized administrators to review active API clients.; FR-006: The system shall authenticate API clients.; FR-007: The system shall enforce role- or policy-based access.; FR-008: The system shall detect repeated failed authentication.; FR-009: The system shall detect unauthorized API requests.; FR-010: The system shall generate security alerts.; FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.; FR-012: The system shall provide a centralized dashboard.; FR-013: The system shall integrate with existing university identity services.; FR-014: The system shall support multiple campus locations.

- Activity: Implement the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
- Activity: In an authorized isolated test environment, execute TEST-001: Given: the system receives a request to access an internal API through a student portal, administrative application, research system, or campus service When: the system evaluates the request against defined access policies and applies role-based restrictions Expected: the system returns a response indicating whether access is granted or denied based on the requester's authenticated identity and authorized roles
- Activity: In an authorized isolated test environment, execute TEST-002: Given: Authorized administrators register APIs When: initiate the registration of a new API endpoint Expected: the newly registered API is available in the access management system for use
- Activity: In an authorized isolated test environment, execute TEST-003: Given: Authorized administrators define access permissions When: define a policy for a named API resource Expected: the named policy definition is available for examination in the system interface
- Activity: In an authorized isolated test environment, execute TEST-004: Given: Authorized administrators approve or revoke application access When: approve a request for application access Expected: the approved decision is observed in the request status field
- Activity: In an authorized isolated test environment, execute TEST-005: Given: Authorized administrators review active API clients When: request a list of currently active API clients Expected: the requested list of active API clients is returned for examination
- Activity: In an authorized isolated test environment, execute TEST-006: Given: the system receives a controlled identity fixture as a principal for API client authentication When: the system submits the principal to authenticate Expected: the system either accepts or rejects the authentication based on the fixture's validity
- Activity: In an authorized isolated test environment, execute TEST-007: Given: the system receives a controlled role or policy permission fixture When: the system evaluates access based on that fixture Expected: the requested access is allowed or denied in accordance with the fixture's defined permissions
- Activity: In an authorized isolated test environment, execute TEST-008: Given: the system receives a controlled sequence of failed authentication attempts When: the system processes the repeated failures Expected: the system identifies the condition of repeated failed authentication
- Activity: In an authorized isolated test environment, execute TEST-009: Given: the system receives a controlled unauthorized API request When: the system processes the request Expected: the system identifies that the request is unauthorized
- Activity: In an authorized isolated test environment, execute TEST-010: Given: an alert condition is initiated using a controlled event fixture When: the system detects and responds to the condition Expected: a security alert exists in the system as a result of the triggered condition
- Activity: In an authorized isolated test environment, execute TEST-011: Given: the system records access decisions, permission changes, and administrator actions using a controlled fixture When: the system maintains logs for these events Expected: audit logs contain entries reflecting those events as they occur

- Activity: In an authorized isolated test environment, execute TEST-012: Given: a user accesses the dashboard named in the source obligation When: the system opens the dashboard as a controlled user Expected: the dashboard is displayed or available for use
- Activity: In an authorized isolated test environment, execute TEST-013: Given: a user initiates an exchange with the external identity service named in the source obligation When: the system performs the interoperation as defined by the source obligation Expected: the system observes successful interoperation with that service
- Activity: In an authorized isolated test environment, execute TEST-014: Given: a user initiates use from each campus location named in the source obligation When: the system supports the use as defined by the source obligation Expected: use succeeds at each location
- Activity: In an authorized isolated test environment, execute TEST-015: Given: A draft acceptance plan for this quality goal: the system shall be secure against unauthorized access and data exfiltration via API endpoints. When: An analyst inspects or reviews that acceptance plan to determine whether measurable targets are defined or remain TBD. Expected: The plan's measurable targets remain TBD or unconfirmed, as no specific thresholds, attack scenarios, or success/failure criteria are provided in the draft plan.
- Activity: In an authorized isolated test environment, execute TEST-016: Given: The system shall remain secure under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: In an authorized isolated test environment, execute TEST-017: Given: The system shall remain reliable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: In an authorized isolated test environment, execute TEST-018: Given: The system shall remain scalable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: In an authorized isolated test environment, execute TEST-019: Given: The system shall remain manageable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
- Activity: Collect stakeholder feedback; agree its cadence with a human reviewer before scheduling cycles.
- Activity: Return accepted stakeholder feedback and observed defects to the backlog and plan the next iteration.
- Deliverable: Requirement-linked implementation increment
- Deliverable: Recorded test evidence
- Deliverable: Reviewed feedback and next-iteration backlog
- Entry criterion: Prior work, source scope and the reviewed test plan are available for iteration planning.
- Exit criterion: A human reviewer has assessed the increment, test evidence and feedback; unresolved changes return to the next iteration.
- Security check: Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
- Security check: Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
- Security check: Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.

- Security check: Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
- Security check: Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.
- Security check: Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.
- Security check: Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

C.2.3 Release and handoff

Proposed roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Linked requirements: FR-001, FR-002, FR-003, FR-004, FR-005, FR-006, FR-007, FR-008, FR-009, FR-010, FR-011, FR-012, FR-013, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005

Human gate: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

- Activity: Review the exact requirements baseline, implementation links and verification evidence before a release decision.
- Activity: Carry unresolved source decisions into handoff; generated text is not human approval.
- Deliverable: Requirements and verification evidence package
- Deliverable: Pending human release decision
- Deliverable: Outstanding-decision record
- Entry criterion: Verification evidence and unresolved decisions are available for human review.
- Exit criterion: A human has recorded the release/handoff decision for the reviewed content.
- Security check: Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
- Security check: Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
- Security check: Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.
- Security check: Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
- Security check: Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
- Security check: Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.
- Security check: Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.

- Security check: Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
- Security check: Review implementation and acceptance evidence against NFR-001: The system shall be secure.
- Security check: Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

Detailed acceptance criteria, evidence, architecture and the SDLC plan are available in the supporting report and canonical JSON.

Canonical content SHA-256: cfb9919f383f83217b70b1d6cdb9be8d50bb178c6d53887d9e1dfa9823dd7500